Module 4: AWS Cloud Security

AWS Academy Cloud Foundations

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Module overview

Topics

- AWS shared responsibility model
- AWS Identity and Access Management (IAM)
- Securing a new AWS account
- Securing accounts
- Securing data on AWS
- Working to ensure compliance

Activities

- AWS shared responsibility model activity

Demo

- Recorded demonstration of IAM

Lab

- Introduction to AWS IAM

Knowledge check

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Module objectives

After completing this module, you should be able to:

- Recognize the shared responsibility model
- Identify the responsibility of the customer and AWS
- Recognize IAM users, groups, and roles
- Describe different types of security credentials in IAM
- Identify the steps to securing a new AWS account
- Explore IAM users and groups
- Recognize how to secure AWS data
- Recognize AWS compliance programs

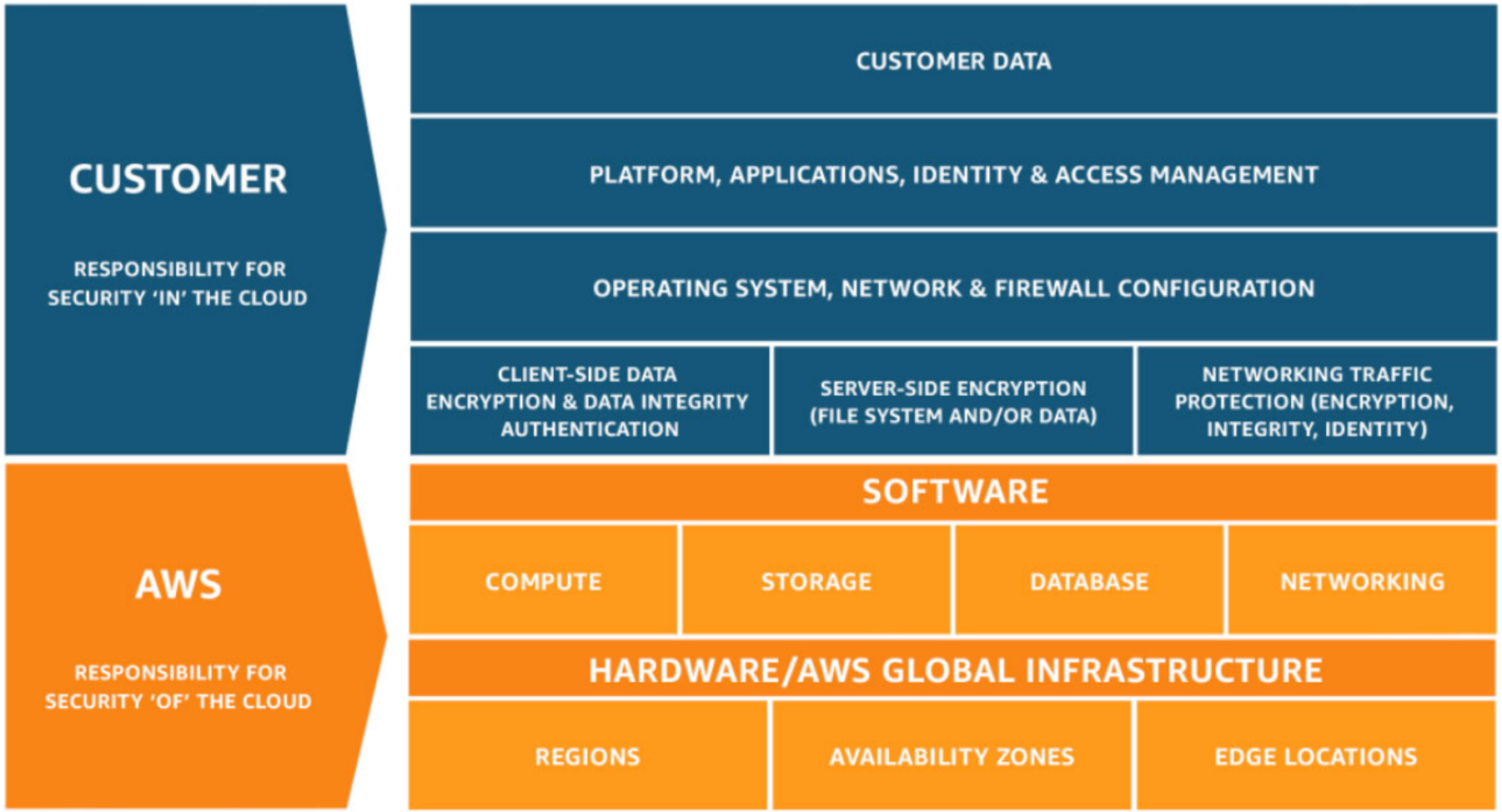
© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Section 1: AWS shared responsibility model

Module 4: AWS Cloud Security

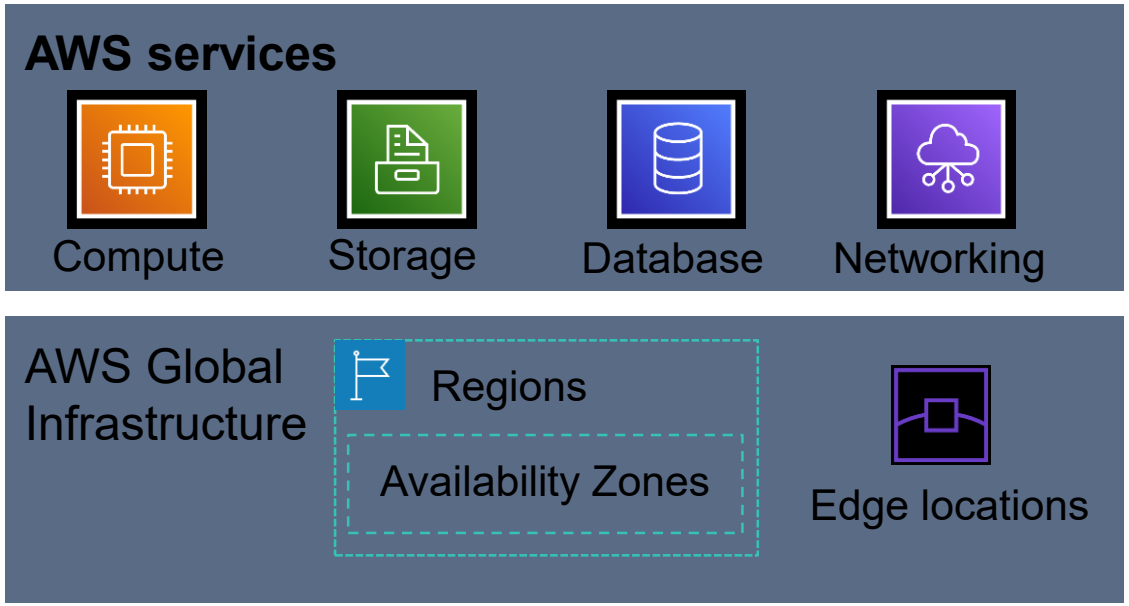
© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AWS shared responsibility model



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AWS responsibility: Security *of* the cloud



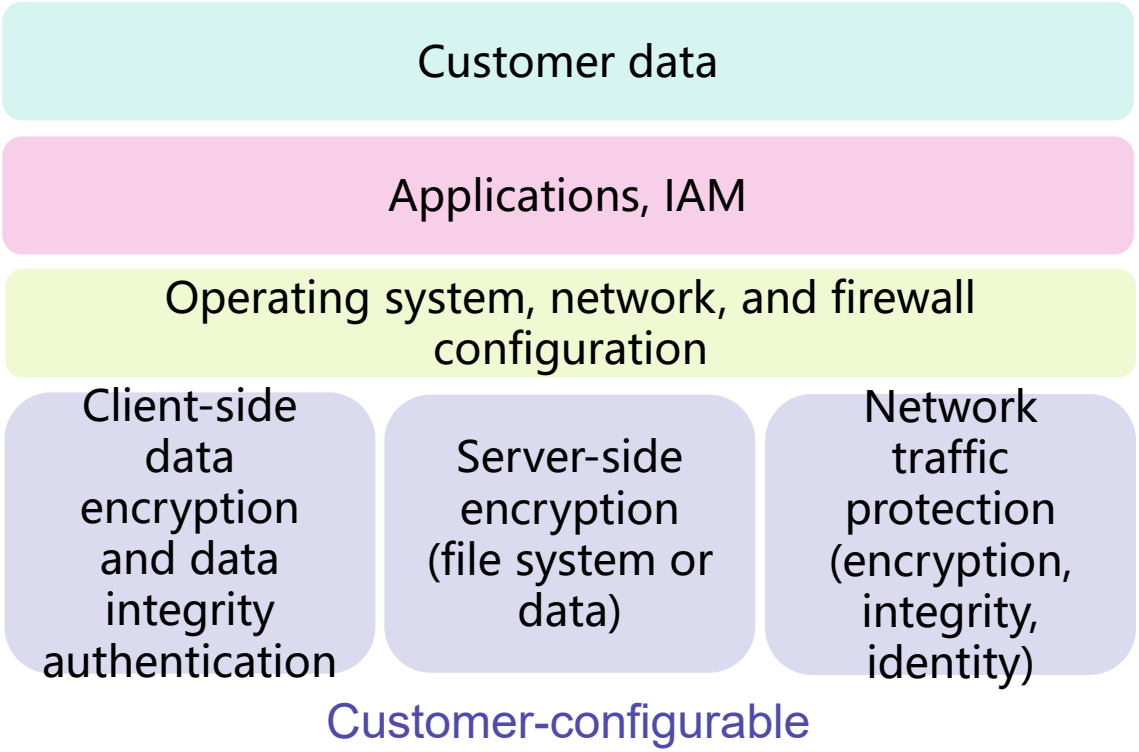
AWS responsibilities:

- Physical security of data centers
  - Controlled, need-based access
- Hardware and software infrastructure
  - Storage decommissioning, host operating system (OS) access logging, and auditing
- Network infrastructure
  - Intrusion detection

- Virtualization infrastructure
  - Instance isolation

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Customer responsibility: Security *in* the cloud



Customer responsibilities:

- Amazon Elastic Compute Cloud (Amazon EC2) instance operating system
  - Including patching, maintenance
- Applications
  - Passwords, role-based access, etc.
- Security group configuration
- OS or host-based firewalls
  - Including intrusion detection or prevention systems
- Network configurations
- Account management
  - Login and permission settings for each user

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Service characteristics and security responsibility (1 of 2)

Example services managed by the customer

Amazon EC2

Amazon Elastic Block Store (Amazon EBS)

Amazon Virtual Private Cloud (Amazon VPC)

Example services managed by AWS

AWS Lambda

Amazon Relational Database Service (Amazon RDS)

AWS Elastic Beanstalk

Infrastructure as a service (IaaS)

- Customer has more flexibility over configuring networking and storage settings
- Customer is responsible for managing more aspects of the security
- Customer configures the access controls

Platform as a service (PaaS)

- Customer does not need to manage the underlying infrastructure
- AWS handles the operating system, database patching, firewall configuration, and disaster recovery
- Customer can focus on managing code or data

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Service characteristics and security responsibility (2 of 2)

SaaS examples

AWS Trusted Advisor

AWS Shield

Amazon Chime

Software as a service (SaaS)

- Software is centrally hosted
- Licensed on a subscription model or pay-as-you-go basis.
- Services are typically accessed via web browser, mobile app, or application programming interface (API)
- Customers do not need to manage the infrastructure that supports the service

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

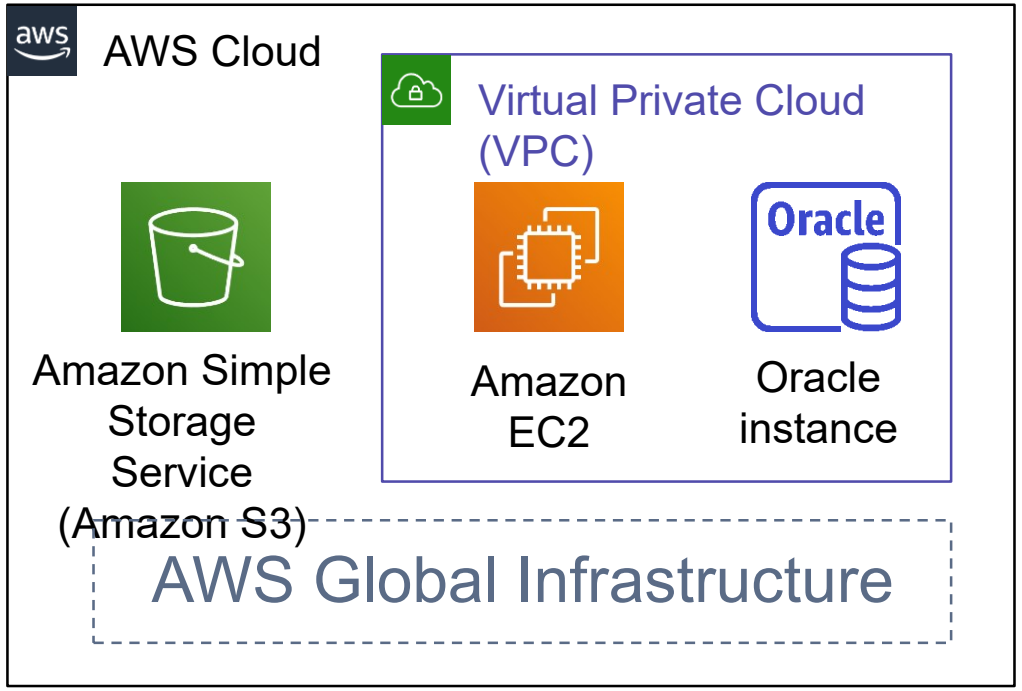
Activity: AWS shared responsibility model

Photo by Pixabay from Pexels.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Activity: Scenario 1 of 2

Consider this deployment. Who is responsible – AWS or the customer?

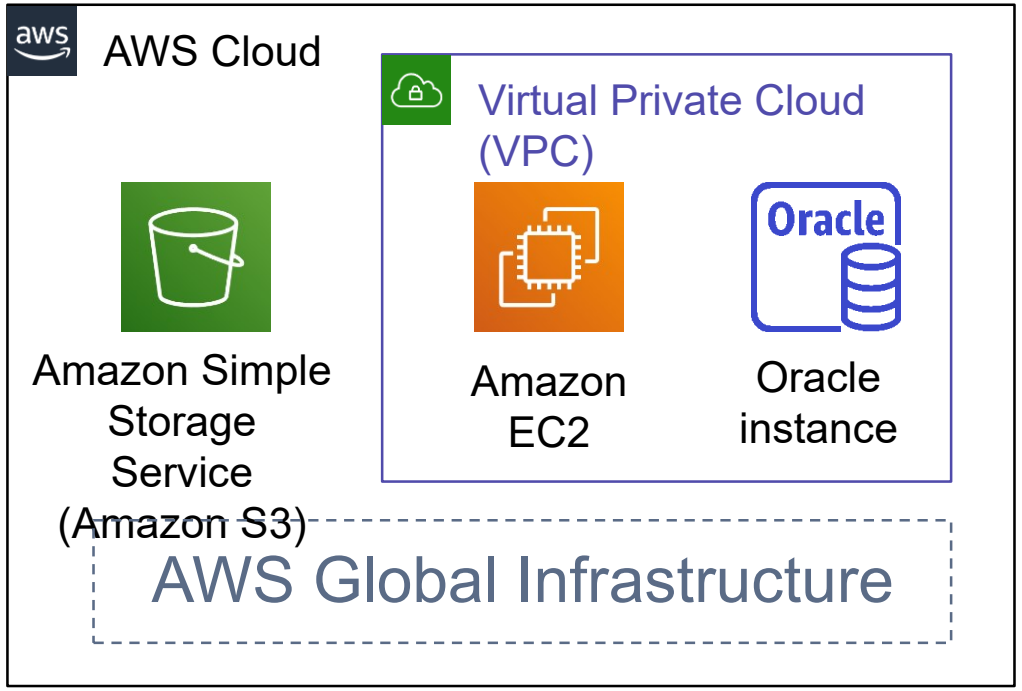


1. Upgrades and patches to the operating system on the EC2 instance?
2. Physical security of the data center?
3. Virtualization infrastructure?
4. EC2 security group settings?
5. Configuration of applications that run on the EC2 instance?
6. Oracle upgrades or patches If the Oracle instance runs as an Amazon RDS instance?
7. Oracle upgrades or patches If Oracle runs on an EC2 instance?
8. S3 bucket access configuration?

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Activity: Scenario 1 of 2 Answers

Consider this deployment. Who is responsible – AWS or the customer?

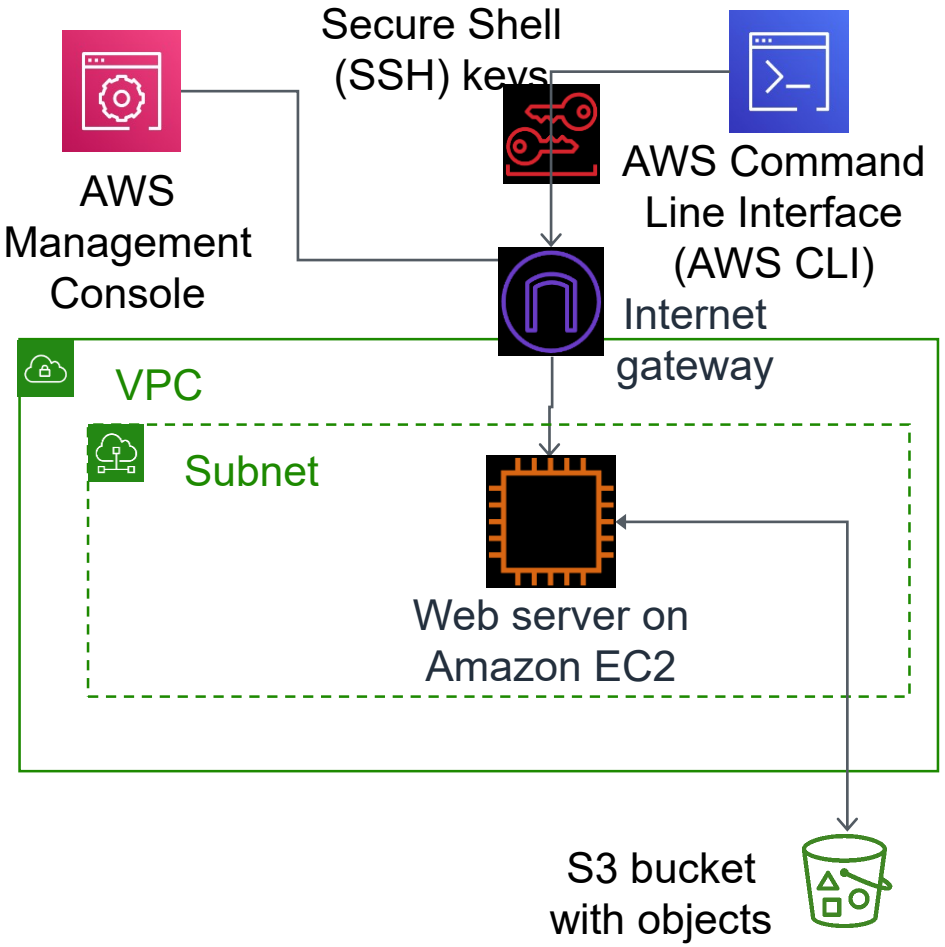


1. Upgrades and patches to the operating system on the EC2 instance?
   - **ANSWER:** The customer
2. Physical security of the data center?
   - **ANSWER:** AWS
3. Virtualization infrastructure?
   - **ANSWER:** AWS
4. EC2 security group settings?
   - **ANSWER:** The customer
5. Configuration of applications that run on the EC2 instance?
   - **ANSWER:** The customer
6. Oracle upgrades or patches If the Oracle instance runs as an Amazon RDS instance?
   - **ANSWER:** AWS
7. Oracle upgrades or patches If Oracle runs on an EC2 instance?
   - **ANSWER:** The customer
8. S3 bucket access configuration?
   - **ANSWER:** The customer

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Activity: Scenario 2 of 2

Consider this deployment. Who is responsible – AWS or the customer?

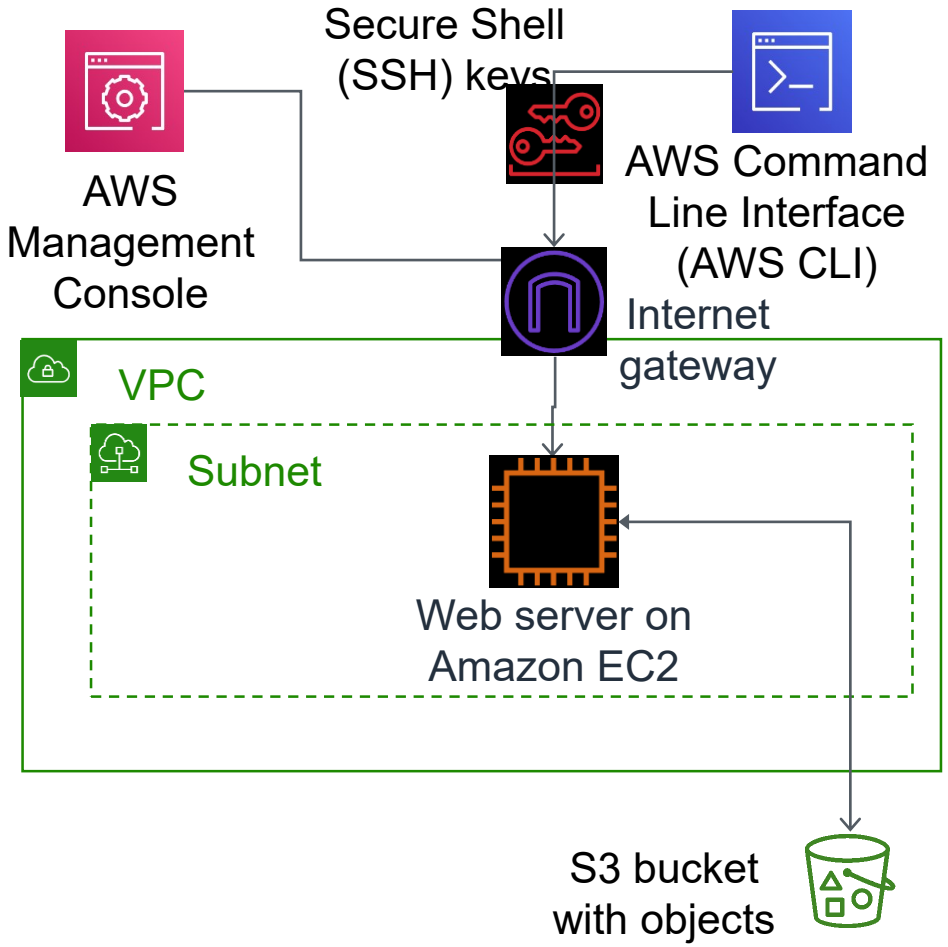


1. Ensuring that the AWS Management Console is not hacked?
2. Configuring the subnet?
3. Configuring the VPC?
4. Protecting against network outages in AWS Regions?
5. Securing the SSH keys
6. Ensuring network isolation between AWS customers' data?
7. Ensuring low-latency network connection between the web server and the S3 bucket?
8. Enforcing multi-factor authentication for all user logins?

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Activity: Scenario 2 of 2 Answers

Consider this deployment. Who is responsible – AWS or the customer?



1. Ensuring that the AWS Management Console is not hacked?
   - **ANSWER:** AWS
2. Configuring the subnet?
   - **ANSWER:** The customer
3. Configuring the VPC?
   - **ANSWER:** The customer
4. Protecting against network outages in AWS Regions?
   - **ANSWER:** AWS
5. Securing the SSH keys
   - **ANSWER:** The customer
6. Ensuring network isolation between AWS customers' data?
   - **ANSWER:** AWS
7. Ensuring low-latency network connection between the web server and the S3 bucket?
   - **ANSWER:** AWS
8. Enforcing multi-factor authentication for all user logins?
   - **ANSWER:** The customer

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Section 1 key takeaways

- AWS and the customer share security responsibilities:
  - AWS is responsible for security of the cloud
  - Customer is responsible for security in the cloud
- **AWS is responsible for protecting the infrastructure**—including hardware, software, networking, and facilities—that run AWS Cloud services
- For services that are categorized as infrastructure as a service (IaaS), the **customer is responsible for performing necessary security configuration and management tasks**
  - For example, guest OS updates and security patches, firewall, security group configurations

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Section 2: AWS Identity and Access Management (IAM)

Module 4: AWS Cloud Security

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AWS Identity and Access Management (IAM)

- Use **IAM** to manage access to **AWS resources** –
  - A resource is an entity in an AWS account that you can work with
  - Example resources; An Amazon EC2 instance or an Amazon S3 bucket

- *Example* – Control who can terminate Amazon EC2 instances

- Define fine-grained access rights –
  - **Who** can access the resource
  - **Which** resources can be accessed and what can the user do to the resource
  - **How** resources can be accessed

- IAM is a no-cost AWS account feature

AWS Identity and Access Management (IAM)

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

IAM: Essential components

IAM user

A **person** *or* **application** that can authenticate with an AWS account.

IAM group

A **collection of IAM users** that are granted identical authorization.

IAM policy

The document that defines **which resources can be accessed** and the **level of access** to each resource.

IAM role

Useful mechanism to grant a set of permissions for making AWS service requests.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Authenticate as an IAM user to gain access

When you define an **IAM user**, you select what ***types of access*** the user is permitted to use.

Programmatic access

- Authenticate using:
  - Access key ID
  - Secret access key
- Provides AWS CLI and AWS SDK access

AWS CLI

AWS Tools and SDKs

AWS Management Console access

- Authenticate using:
  - 12-digit Account ID *or* alias
  - IAM user name
  - IAM password
- If enabled, **multi-factor authentication (MFA)** prompts for an authentication code.

AWS Management Console

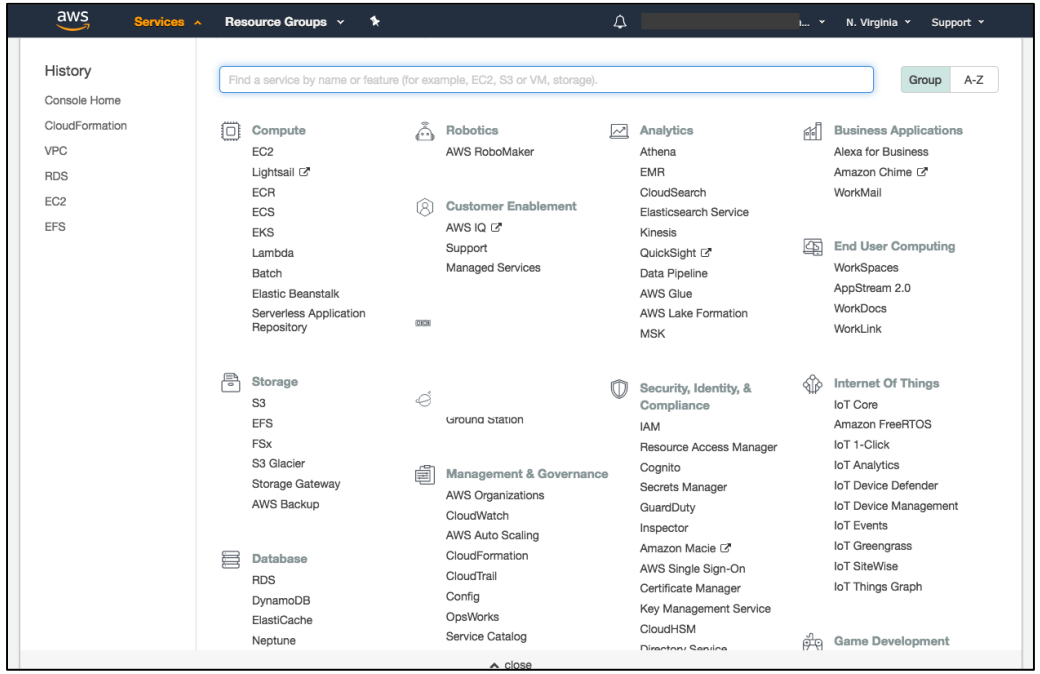
© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

IAM MFA

- MFA provides increased security.
- In addition to **username** and **password**, MFA requires a unique authentication code to access AWS services.

Username and password

MFA token

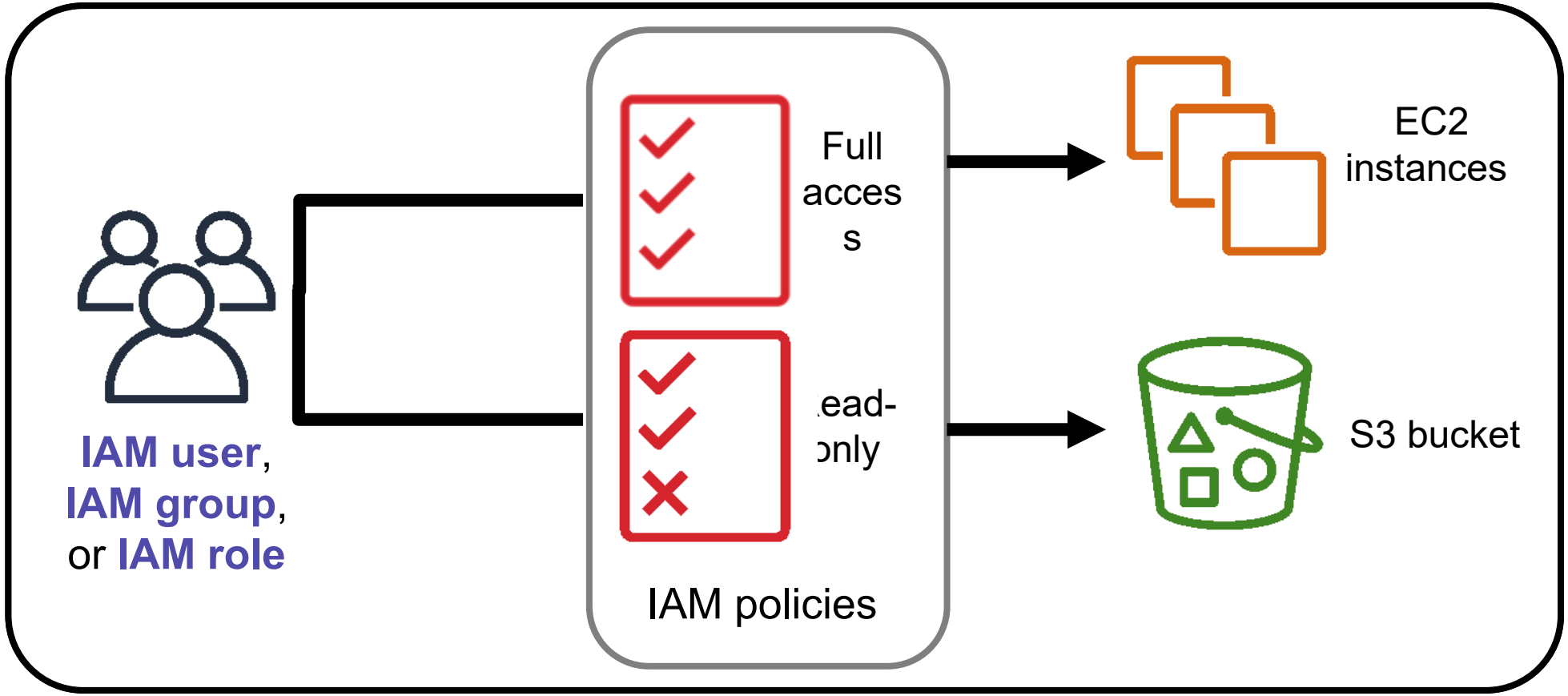


AWS Management Console

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Authorization: What actions are permitted

After the user or application is connected to the AWS account, what are they allowed to do?



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

IAM: Authorization

- Assign permissions by creating an IAM policy.
- Permissions determine **which resources and operations** are allowed:
  - All permissions are implicitly denied by default.
  - If something is explicitly denied, it is never allowed.

Best practice: Follow the **principle of least privilege**.

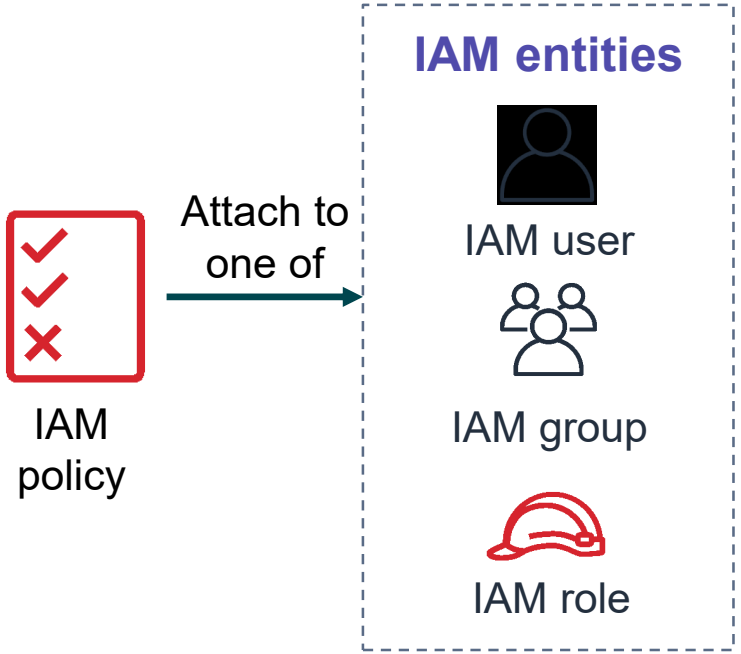
IAM permissions

Note: The scope of IAM service configurations is **global**. Settings apply across all AWS Regions.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

IAM policies

- **An IAM policy is a document that defines permissions**
  - Enables fine-grained access control
- Two types of policies – *identity-based* and *resource-based*
- **Identity-based** policies –
  - Attach a policy to any IAM entity
    - An IAM user, an IAM group, or an IAM role
  - Policies specify:
    - Actions that ***may*** be performed by the entity
    - Actions that ***may not*** be performed by the entity
  - A single *policy* can be attached to multiple *entities*
  - A single *entity* can have multiple *policies* attached to it
- **Resource-based** policies
  - Attached to a resource (such as an S3 bucket)



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

IAM policy example

```
{
  "Version": "2012-10-17",
  "Statement":[{
    "Effect":"Allow",
    "Action":["DynamoDB:*","s3:*"],
    "Resource":[
      "arn:aws:dynamodb:region:account-number-without-hyphens:table/table-name",
      "arn:aws:s3:::bucket-name",
      "arn:aws:s3:::bucket-name/*"]
    },
    {
    "Effect":"Deny",
    "Action":["dynamodb:*","s3:*"],
    "NotResource":["arn:aws:dynamodb:region:account-number-without-hyphens:table/table-name”,
      "arn:aws:s3:::bucket-name",
      "arn:aws:s3:::bucket-name/*"]
    }
  ]
}
```

Explicit allow gives users access to a specific DynamoDB table and…

…Amazon S3 buckets.

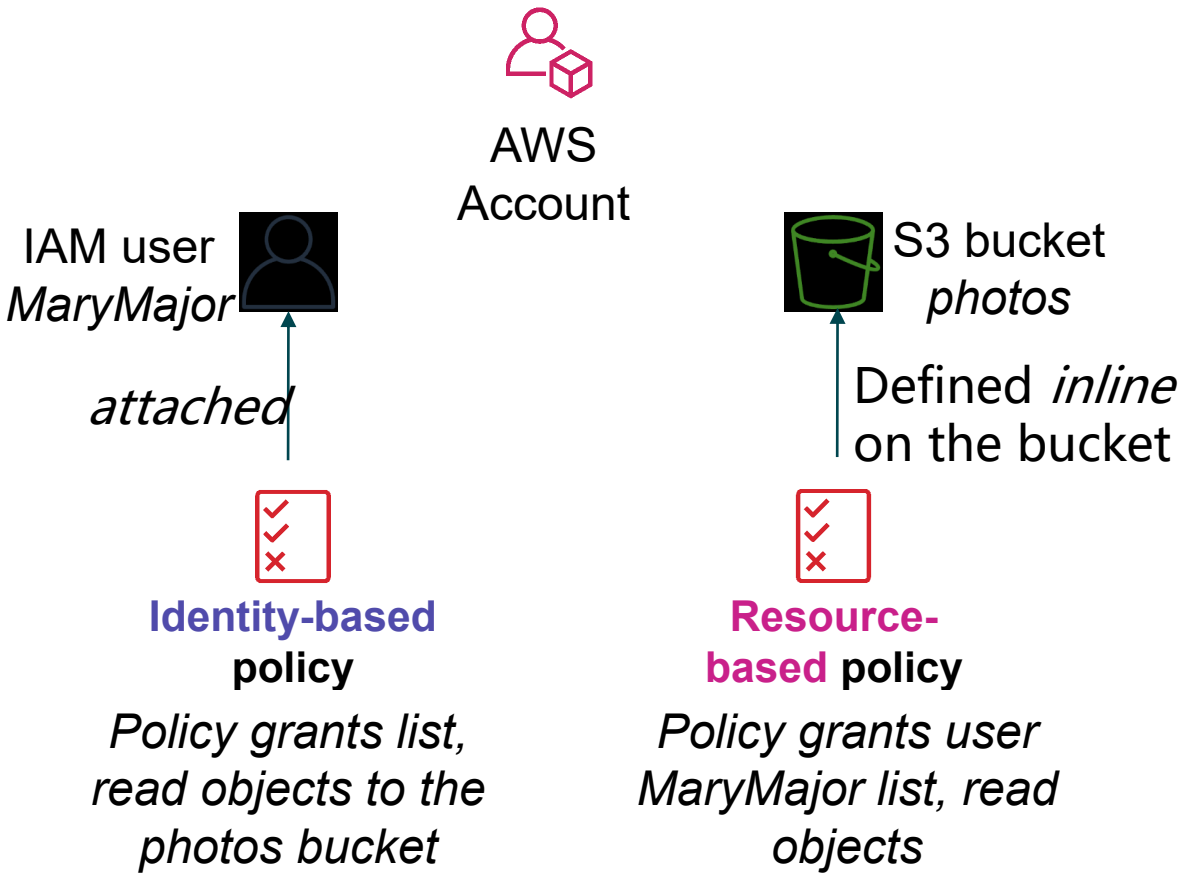
Explicit deny ensures that the users cannot use any other AWS actions or resources other than that table and those buckets.

An explicit deny statement **takes precedence** over an allow statement.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Resource-based policies

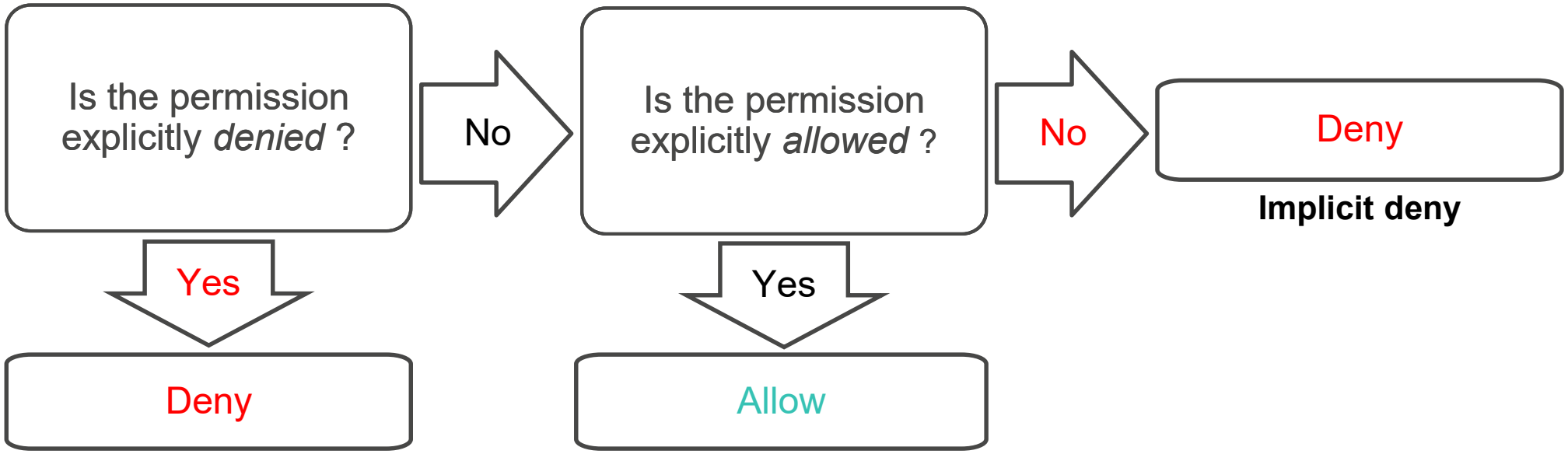
- *Identity-based policies* are attached to a user, group, or role
- **Resource-based policies** are attached to a resource (*not* to a user, group or role)
- Characteristics of resource-based policies –
  - Specifies who has access to the resource and what actions they can perform on it
  - The policies are *inline* only, not managed
- Resource-based policies are supported only by some AWS services



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

IAM permissions

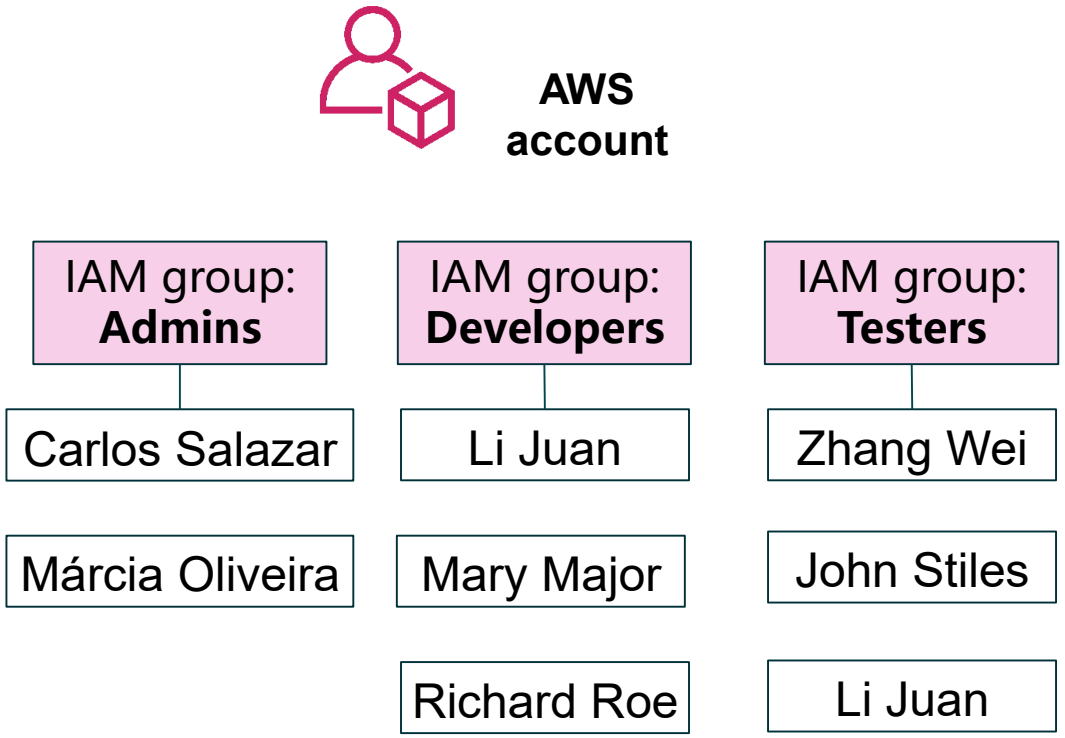
How IAM determines permissions:



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

IAM groups

- An **IAM group** is a collection of IAM users
- A group is used to grant the same permissions to multiple users
  - Permissions granted by attaching IAM *policy* or policies to the group
- A user can belong to multiple groups
- There is no default group
- Groups cannot be nested



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

IAM roles

- An **IAM role** is an IAM identity with specific permissions
- Similar to an IAM user
  - Attach permissions policies to it
- Different from an IAM user
  - Not uniquely associated with one person
  - Intended to be *assumable* by a **person**, **application**, or **service**
- Role provides *temporary* security credentials
- Examples of how IAM roles are used to **delegate** access –
  - Used by an IAM user in the same AWS account as the role
  - Used by an AWS service—such as Amazon EC2—in the same account as the role
  - Used by an IAM user in a different AWS account than the role

IAM role

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

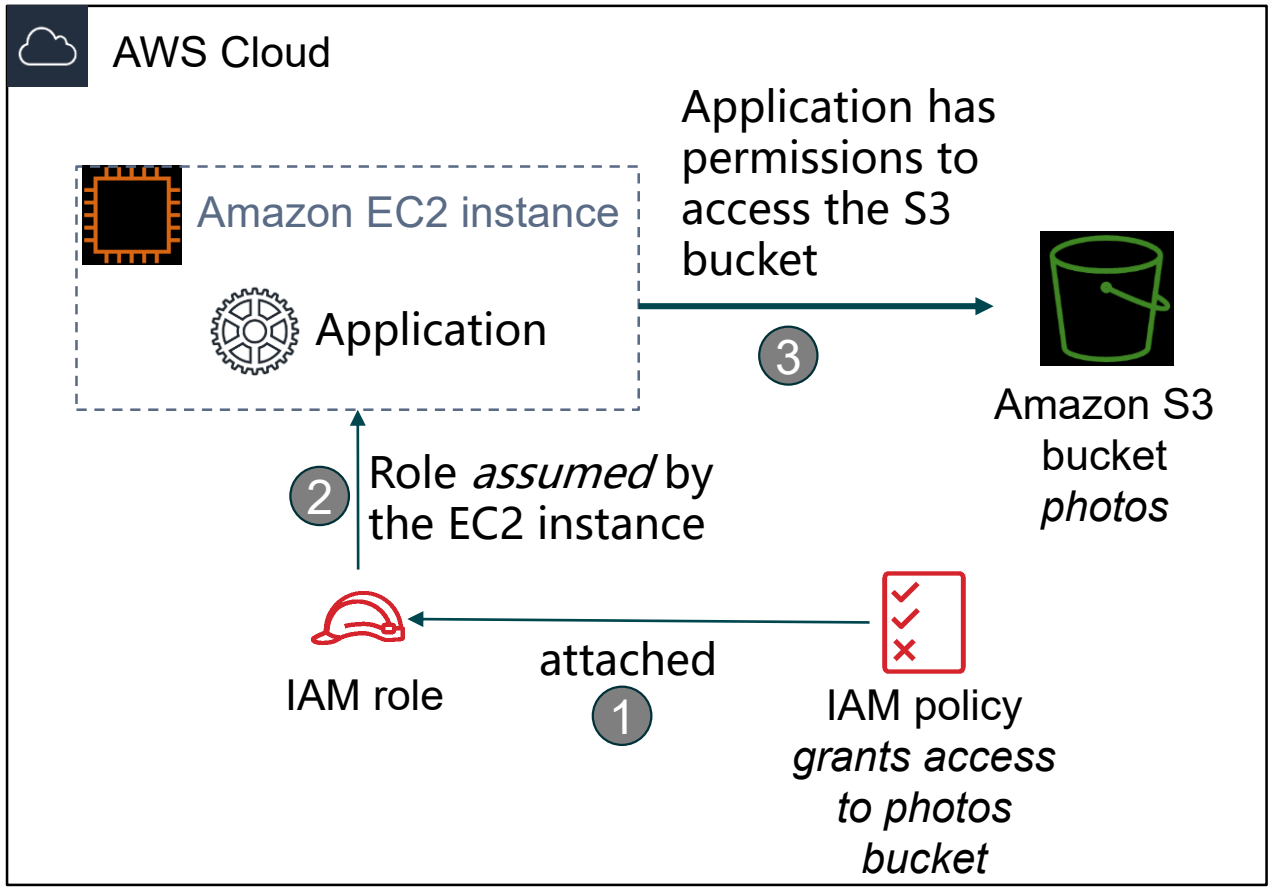
Example use of an IAM role

Scenario:

- An application that runs on an EC2 instance needs access to an S3 bucket

Solution:

- Define an IAM policy that grants access to the S3 bucket.
- Attach the policy to a role
- Allow the EC2 instance to assume the role



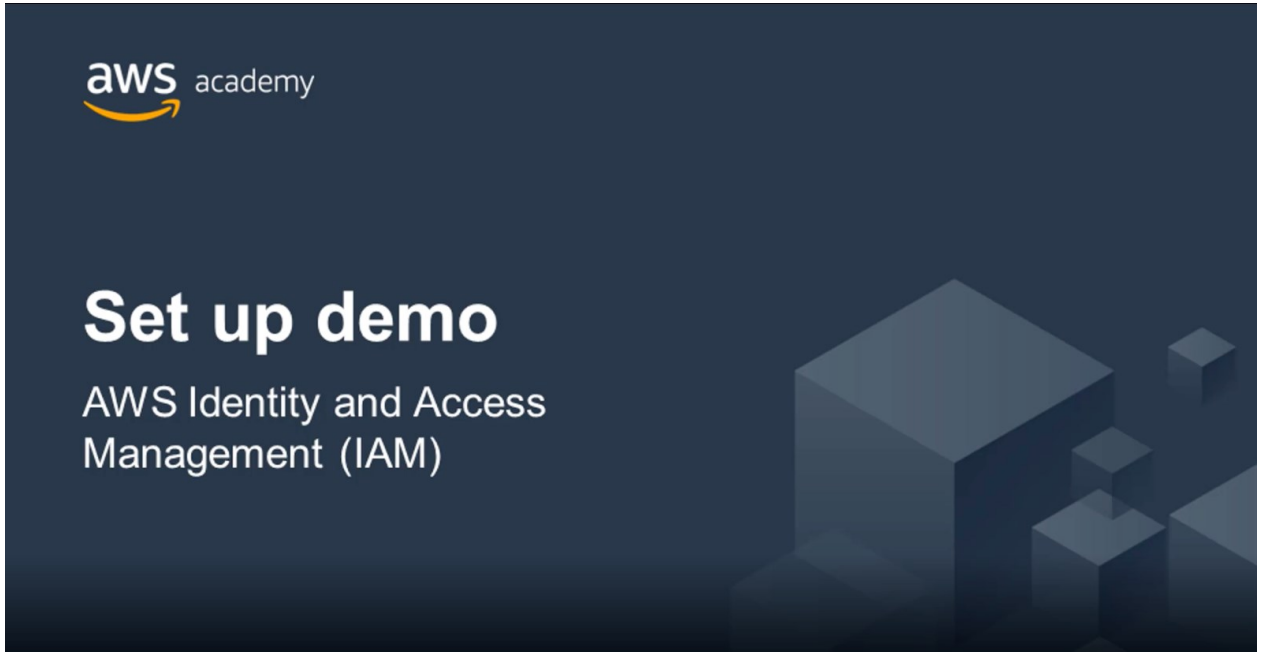
© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Section 2 key takeaways

- **IAM policies** are constructed with JavaScript Object Notation (JSON) and define permissions.
  - IAM policies can be attached to any **IAM entity**.
  - Entities are IAM users, IAM groups, and IAM roles.
- An **IAM user** provides a way for a person, application, or service to authenticate to AWS.
- An **IAM group** is a simple way to attach the same policies to multiple users.
- An **IAM role** can have permissions policies attached to it and can be used to delegate temporary access to users or applications.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Recorded demo: IAM



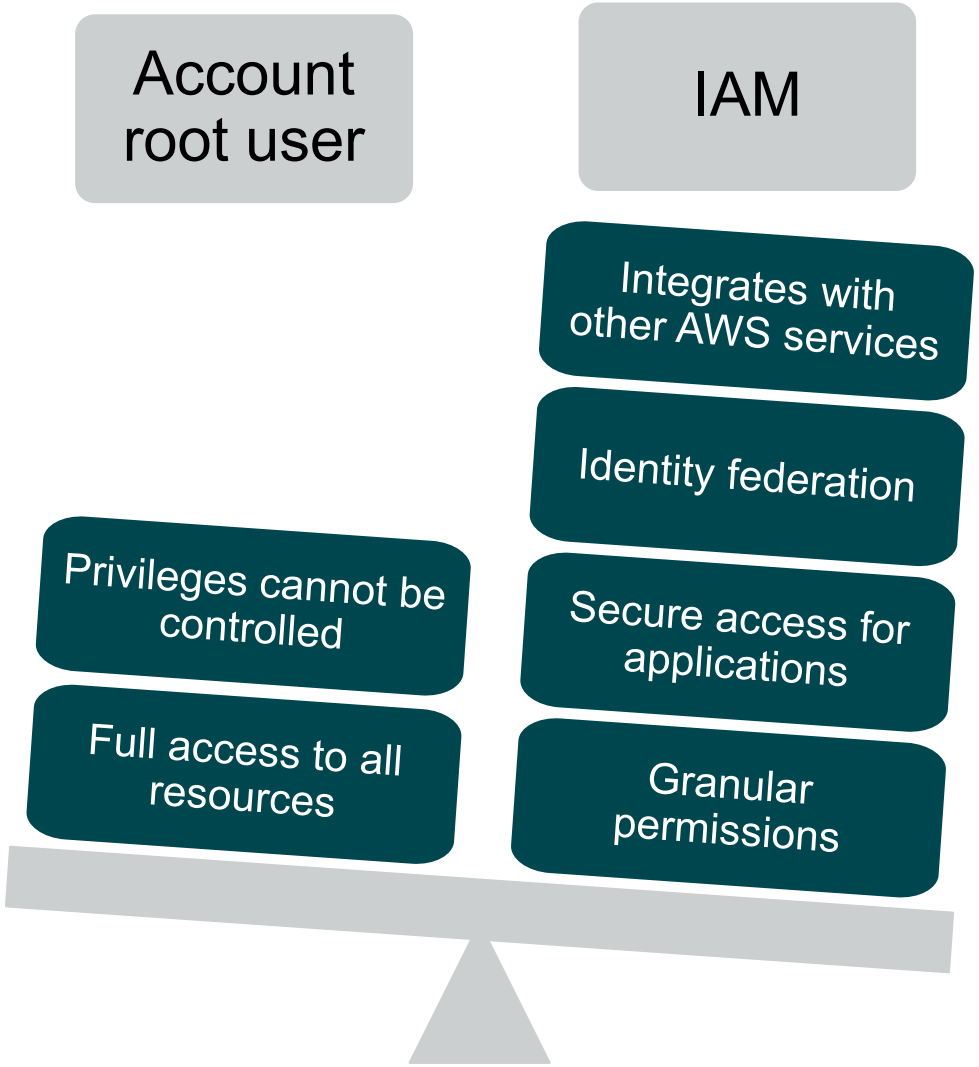
© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Section 3: Securing a new AWS account

Module 4: AWS Cloud Security

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AWS account root user access versus IAM access



- **Best practice**: Do not use the AWS account root user except when necessary.
  - Access to the **account root user** requires logging in with the *email address* (and password) that you used to create the account.
- Example actions that can only be done with the account root user:
  - Update the account root user password
  - Change the AWS Support plan
  - Restore an IAM user's permissions
  - Change account settings (for example, contact information, allowed Regions)

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Securing a new AWS account: Account root user

Step 1: Stop using the account root user as soon as possible.

- The account root user has unrestricted access to all your resources.

- To stop using the account root user:
  1. While you are logged in as the account root user, create an IAM user for yourself. Save the access keys if needed.
  2. Create an IAM group, give it full administrator permissions, and add the IAM user to the group.
  3. Disable and remove your account root user access keys, if they exist.
  4. Enable a password policy for users.
  5. Sign in with your new IAM user credentials.
  6. Store your account root user credentials in a secure place.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Securing a new AWS account: MFA

Step 2: Enable multi-factor authentication (MFA).

- Require MFA for your account root user and for all IAM users.
- You can also use MFA to control access to AWS service APIs.

- Options for retrieving the MFA token –
  - Virtual MFA-compliant applications:
    - Google Authenticator.
    - Authy Authenticator (Windows phone app).
  - U2F security key devices:
    - For example, YubiKey.
  - Hardware MFA options:
    - Key fob or display card offered by Gemalto.

MFA token

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Securing a new AWS account: AWS CloudTrail

Step 3: Use AWS CloudTrail.

- CloudTrail tracks user activity on your account.
  - Logs all API requests to resources in all supported services your account.
- Basic AWS CloudTrail event history is enabled by default and is free.
  - It contains all management event data on latest 90 days of account activity.
- To access CloudTrail –
  1. Log in to the **AWS Management Console** and choose the **CloudTrail** service.
  2. Click **Event history** to view, filter, and search the last 90 days of events.
- **To enable logs beyond 90 days and enable specified event alerting, create a trail.**
  1. From the CloudTrail Console trails page, click **Create trail**.
  2. Give it a name, apply it to all Regions, and create a new Amazon S3 bucket for log storage.
  3. Configure access restrictions on the S3 bucket (for example, only admin users should have access).

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Securing a new AWS account: Billing reports

Step 4: Enable a billing report, **such as the AWS Cost and Usage Report.**

- Billing reports provide information about your use of AWS resources and estimated costs for that use.
- AWS delivers the reports to an Amazon S3 bucket that you specify.
  - Report is updated at least once per day.
- The **AWS Cost and Usage Report** tracks your AWS usage and provides estimated charges associated with your AWS account, either by the hour or by the day.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Section 3 key takeaways

Best practices to secure an AWS account:

- **Secure** logins with multi-factor authentication (MFA).
- **Delete** account root user access keys.
- **Create** individual IAM users and grant permissions according to the principle of least privilege.
- **Use groups** to assign permissions to IAM users.
- **Configure** a strong password policy.
- **Delegate** using roles instead of sharing credentials.
- **Monitor** account activity by using AWS CloudTrail.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.